



More GhostPosting

Description: RAM pricing to affect enterprise firewall equipment. Anthropic provides sizeable support to Python Foundation. The FTC clamps down on GM's secret sale of driving data. "ANCHOR" replaces "CIPAC" for industry-government sharing. Germany planning to legislate total access to global data. Grubhub becomes the latest ShinyHunters extortion victim. Let's Encrypt's 6-Day certs are available to everyone. Iran planning to permanently take itself off the Internet. HD Tune before and after a SpinRite Level 3 refresh. Some great listener feedback. Then more trouble from GhostPoster malicious browser extensions.

High quality (64 kbps) mp3 audio file URL: <http://media.GRC.com/sn/SN-1061.mp3>

Quarter size (16 kbps) mp3 audio file URL: <http://media.GRC.com/sn/sn-1061-lq.mp3>

SHOW TEASE: It's time for Security Now!. Steve Gibson is here. We're going to talk about RAM pricing. We're going to talk about Claude Code and vibe coding. The six-day certificates are now out from Let's Encrypt. And yes, it's the return of GhostPoster. Malicious browser extensions you need to watch out for. All that coming up next on Security Now!.

Leo Laporte: This is Security Now! with Steve Gibson, Episode 1061, recorded Tuesday, January 20th, 2026: More GhostPosting.

It's time for Security Now!, the show where we cover your security, your privacy, how computers work, the best sci-fi, vitamins, magnesium and more with this man right here, Mr. Steven Gibson. Hello, Steve.

Steve Gibson: Am I bored or what, Leo?

Leo: No. What you are is a polymath. That's the word. You have many diverse interests, and you are a very quick learner, and you like sharing what you've learned with us. And that's - we're grateful.

Steve: I have to say that probably - that shoe fits. I'll go with that.

Leo: Yeah, yeah. I was always an enthusiast. I would, like, get really excited about something for six months and then lose interest, move on to the next thing. You're a little bit more, thank goodness, devoted.

Steve: A little less, what is that, is that ADHD or ADD or what is it? Does they have some initials for that?

Leo: There's probably some diagnosis, I'm sure.

Steve: I'm sure there is. We're all on the spectrum somewhere.

Leo: Yeah.

Steve: Okay. So we're going to talk about GhostPosting again after more worrisome information surfaced following our first discussion of it four podcasts ago. It was our last podcast of 2025. I thought we were done with it, but no. But more interesting stuff, and some good takeaways, I think, for this Security Now! 1061 for what is happening with January. It's almost gone. It's the 20th. I guess our last podcast of January will be next month, I mean next week. So, wow. Okay.

But we're going to look at other things first, of course. It turns out that not only are PCs going to be affected by what's happening with RAM, but there have been some recent studies and surveys that demonstrate that enterprise, high-end enterprise networking like firewall equipment is similarly going to be hit.

Leo: And it's going to go - oh, I'm sorry.

Steve: Yeah, yeah. Because the high-end equipment is using a lot of RAM in order to do what it's doing. And so we're going to see that going up, too. Anthropic has provided a sizeable support to the Python Foundation, which is good and interesting in a couple ways. The FTC has clamped down on General Motors' secret sale of driving data. A new, it's not an organization, a new, I don't know what it is. It's a government thing.

Leo: Now I know why you don't know what it is, yes.

Steve: Yeah. It's abbreviated ANCHOR, A-N-C-H-O-R...

Leo: Agency, maybe.

Steve: Agency. I like that.

Leo: Okay.

Steve: Agency which replaces, I don't know how you pronounced this except CIPAC, although it's not the CIPAC we're all familiar with, C-I-P-A-C. That was that agency that was terminated shortly after Trump because president for the second time, which is that private/public information sharing, where the industry was relying upon their ability to disclose their own mistakes without fear of retribution from the government. So anyway, we're going to catch up on where that is. Germany, it turns out, is planning to legislate

themselves total access to the Internet's Global Data. And Leo, we were talking about the inability to pronounce things before we began this podcast? I've got a German word that, I mean, it looks like the Scrabble set fell on the ground, and they just assembled the letters in an arbitrary sequence. Luckily, it's got a three-letter abbreviation.

Leo: Okay.

Steve: But anyway, we'll talk about this legislation from this organization in Germany. Grubhub has not completely confessed, but we now know that they are the ShinyHunters' most recent extortion victim.

Leo: Oh, geez.

Steve: Uh-huh. So ShinyHunters, the shine has not been lost yet. Let's Encrypt's six-day certs are now available to anyone who wants them, which is the way it should stay. Not mandatory; but, yeah, okay. I'm really nervous about my ability to protect my certificate, you know, despite the fact that I'm running a web server that has to have one; you know? Okay. So I want six days. Anyway, we'll get there.

Iran has said, actually not said publicly, but there are internal reports and internal machinations which force people to draw the conclusion that they plan to permanently remain off the Internet, as they have been since January 8th. Not coming back. We'll talk about what that means. Also, oh, I got two so cool graphs, an HD Tune before and after - an HD Tune is a utility, you know, HD as in hard disk. It was run on an SSD by one of our listeners and SpinRite owners before and after. And it's my favorite chart.

Also we've got some great listener feedback, and then we're going to get around to talking about the fact that GhostPoster turned out to have been, I hope we can use the past tense, it's not clear, much worse than was believed and that we knew four weeks ago when we talked about it for I think it was 1057 was our last podcast of last year. And of course we've got a Picture of the Week that many of our listeners have written back saying, because I sent this all out yesterday afternoon, early afternoon, they said, oh, yeah, I remember that.

Leo: Okay. Well, I can't wait to remember what that is. But we'll find out in just a little bit.

Steve: It is, yes, it's the follow-on to the famous "Be Kind, Rewind" sticker.

Leo: Oh, yes. Oh, yeah.

Steve: Which Blockbuster put on all of their VHS tapes, you know.

Leo: It was also the name of a movie about a guy who works in a video store. I can't wait. We have lots to talk about. And of course this is the place to talk about it, if you're interested in security. We will get underway with our Picture of the Week. Again, I have sealed myself in a soundproof booth the last seven days. I have no idea what the Picture of the Week is. We will look at it for the first time together.

Although, as you have pointed out, people who subscribe to your newsletter get it a day before, and they've been probably already talking about it and everything, so...

Steve: There have been some discussions.

Leo: I'm always the last to know, yeah.

Steve: Yes. Okay.

Leo: Picture of the Week time?

Steve: So I found the sales pitch for this device, Leo.

Leo: Okay.

Steve: It reads: "Never pay another DVD rewind fee again."

Leo: It's a DVD rewinder.

Steve: It is a DVD rewinder.

Leo: Oh. But wait a minute.

Steve: I know. Wait, hold on. It, no, "it's compatible..."

Leo: Wait a minute.

Steve: "...with all disc formats - with DVD-R, DVD-RW, DVD+R, DVD+RW, CDR, CDRW, Audio CD." In fact, you can see down there that little switch, it says either DVD or MP3.

Leo: Oh, my goodness.

Steve: Also it'll rewind your audio disks, as well.

Leo: Wow.

Steve: So, and then in the marketing material that came along with it they explain. They said: "We've tested the DVD Rewinder with the next-generation disc media including Blu-Ray and HD. The DVD Rewinder also works with Sony PlayStations, Xbox, and other disc-based console system media. The DVD Rewinder works with all disc-based digital media

to provide optimized digital experience. Visual indicators blink, and audible sounds are played while your digital media is 'reversed.' The DVD Rewinder also has" - get this, Leo. This is so clever - "a USB port for MP3 players and USB media." So it will even rewind your USB media when, like, it hits the end, you know, and...

Leo: Even iPods, ladies and gentlemen. Everything. It'll remind your iPod.

Steve: It's an amazing device. I can't understand why it's no longer available. Sometimes you can find one, a stray one, on eBay. But, yeah.

Leo: Oh, my.

Steve: You know, sometimes the most obvious things just - you just miss them.

Leo: I want this for the next White Elephant party because that would be a great giveaway.

Steve: Someone comes along, and they go, oh, nobody did a rewinder for DVDs. It's like the missing link.

Leo: Be kind. Rewind that DVD.

Steve: That's right. That's right. And the truth is, Leo, that when Blockbuster switched from tapes to DVDs...

Leo: Yes.

Steve: ...the employees still put the "Be Kind, Please Rewind" sticker...

Leo: On the box?

Steve: ...on the DVD boxes.

Leo: That's hysterical. Well, that probably stimulated the demand for this DVD Rewinder.

Steve: They were, well, what are you going to do? You don't want one of those fees. Sometimes, in some places, which could charge you a fee if you did not...

Leo: If you didn't rewind.

Steve: ...rewind your media. So you could probably hold this up and show them, hey, I have a DVD rewinder. These are - all the DVDs I'm returning are fully rewound.

Leo: Steve, you understand there's an entire group of members of our audience that have no idea what we're talking about. They've never been to a video store.

Steve: Fortunately, the bulk of our audience are old. They're probably where we are.

Leo: But seriously, there's a whole generation that's never seen a VHS cassette.

Steve: That's true.

Leo: That's amazing. And soon there'll be a generation that's never seen a CD or a DVD.

Steve: Well, and I was saying to Lorrie the other day, imagine kids now growing up never - being in a world that never had AI that you could talk to and would answer. I mean, it's - here all of us oldies are like, oh my god, have you seen what it can do?

Leo: It's amazing.

Steve: You know? It is. And now...

Leo: It's just everyday for them.

Steve: And now the next round they're going to be like, eh, yeah, you know, I just grokked it.

Leo: Yeah. I just grokked it. Let's hope that does not become the verb. I'm just saying.

Steve: Yeah, yeah. Okay. So any of our listeners who provide purchase planning guidance for high-end network security products may wish to consider advising those who have, you know, make the final decisions that maybe they should be purchasing sooner rather than later if, like, they already know what they were going to do but just haven't pulled the trigger. Some recent commentary about the effect the rising cost of RAM will also likely have on the security equipment sector suggested that prices could be expected to rise there, as well, shortly.

The commentary said: "The current price hikes and supply shortage of DRAM memory chips are expected to also impact firewall makers and the cybersecurity market. DRAM is a crucial component for the manufacturing of modern next-gen firewalls, a staple in the cybersecurity defense of any major enterprise.

"Investment advisory firm Wedbush says firewall companies will see thinner margins this year due to the rising DRAM costs. This will impact their bills of materials, with the extra costs being passed on to customers as product price increases. This will likely lead to lower sales, smaller profit margins, and weaker investor yields. Companies like Fortinet, Palo Alto Networks, and Check Point are expected to see the biggest headwinds on the stock market this year as a result of DRAM hikes.

"Firewall makers join laptop, PC, and smartphone vendors, all of which are expected to see big headwinds this year due to collapsing sales. DRAM prices have been up between 60% and 70% since last year and are expected to grow another 50% in the first quarter of the year alone.

"The production of most of this year's DRAM supply has already been purchased by AI companies for use in their future data centers. DRAM maker Micron has exited the consumer market and focused strictly on supplying AI and data center makers. South Korean company SK Hynix is also pondering a similar decision from both the DRAM and NAND/SSD markets."

So I mentioned previously that I purchased my next small form factor desktop PC from Lenovo a couple of months ago before I planned to deploy it, probably March, another two months still. And I did that due to the expectation that PC vendors will soon have no choice other than to raise the prices for their systems. And since it'll be done across the board by the industry, it's not like they're going to, you know, lose out the competition. The competition's going to have to do the same thing, as well.

And I also had mentioned previously, several months before that, that I was, I had become similarly glad to have recently purchased replacement servers for GRC after the second of the five that I currently had, had died. That used up, the two dying out of five, you know, used up my margin. I no longer had any spares. So I wanted to be ready with replacement servers standing by in case I were to lose another. At the time, those server replacements were for that "just in case" instance. But now I'm glad, since I always prefer to stuff my servers with as much RAM as they can handle, you know, that's a good thing for their health. And last summer, RAM was still amazingly inexpensive. Not so any longer.

So I think that the takeaway here, is that, as I said, if somebody already had plans to purchase high-end RAM-intensive network security equipment, like sometime soon, it might make sense to cut the purchase order, like very soon, because prices are expected to rise. Again, not surprisingly. The little small form factor PC that I purchased, I was unable to max out its RAM, and I went looking for the balance. And I decided, okay, I'm going to wait because this crazy RAM pricing is not expected to last forever. I hope it doesn't. But at the current RAM prices, I'm not willing to buy another 64GB to bring this thing up to 128. I'll stay where I am. Which should be fine. Or maybe it was 32, and it can take 64. I don't quite remember. But I looked at current prices, and it's like, ow. Yeah. I don't need it that badly.

Leo: Let's hope you're, you know, you're where you need to be for now; right?

Steve: Yeah. Oh, yeah. It had at least 32GB, which - maybe 64. I'm not sure. But it could take twice what I had. And I thought, well, I want to give it all I can. Because I expect to be more in a virtual machine environment also, you know, moving forward.

Leo: Right.

Steve: Last week, the Python Software Foundation announced some very welcome financial support from Anthropic. Under their headline "Anthropic invests \$1.5 million in the Python Software Foundation and open source security," they wrote: "We are thrilled to announce that Anthropic has entered into a two-year partnership with the Python Software Foundation to contribute a landmark total of \$1.5 million to support the foundation's work, with an emphasis on Python ecosystem security. This investment will enable the PSF" - that's Python Software Foundation, the PSF - "to make crucial security advances to CPython" - that's the Python written in a hybrid of C and Python itself.

Leo: Actually it's the Python that compiles - it's written in C and compiles to C, but you write in Python. CPython.

Steve: Oh. Wait. And so written in C.

Leo: Well, I think Python in general is written in C. Some of the libraries are written in Python, but CPython...

Steve: Right.

Leo: Instead of - so Python's normally an interpreter.

Steve: Right.

Leo: CPython writes C code, which is then compiled.

Steve: I see. I got you, got you. So it outputs C code that is then compiled.

Leo: Yeah. Yeah.

Steve: Ah, got it.

Leo: That's my understanding. I may be wrong. Correct me if I'm wrong, chatroom.

Steve: So CPython and also PyPI, which we're talking about all the time.

Leo: Oh, yes.

Steve: For not good reasons. The Python Package Index will also be receiving the benefit of this.

Leo: This is great.

Steve: So, yeah. It's really good. And so they said: It will also sustain the foundation's core work supporting the Python language ecosystem and global community.

Leo: This is because Python is really the language of AI.

Steve: Of AI, exactly.

Leo: So Anthropic's.

Steve: And they said: "Anthropic's funds will enable the PSF" - well, exactly, it's a strategic investment, right, on Anthropic's part.

Leo: Exactly, yeah.

Steve: "Anthropic's funds," they said, "will enable the PSF to make progress on our security roadmap, including work designed to protect millions of PyPI users from attempted supply-chain attacks." And get this. "Planned projects include creating new tools for automated proactive review of all packages uploaded to PyPI, improving on the current process of reactive-only review. We intend to create a new dataset of known malware that will allow us to design these novel tools, relying on capability analysis. One of the advantages of this project is that we expect the outputs we develop to be transferable to all open source package repositories. As a result, this work has the potential to ultimately improve security across multiple open source ecosystems, starting with the Python ecosystem.

"This work will build on PSF Security Developer in Residence Seth Larson's security roadmap with contributions from PyPI Safety and Security Engineer Mike Fiedler, both roles generously funded by Alpha-Omega. Anthropic's support will also go towards the PSF's core work, including the Developer in Residence program driving contributions to CPython, community support through grants and other programs, running core infrastructure such as PyPI, and more. We could not be more grateful for Anthropic's remarkable support, and we hope you will join us in thanking them for their investment in the PSF and the Python community." So as you said, Leo, this is great and welcome news.

Leo: Oh, yeah, yeah.

Steve: \$1.5 million likely makes a big difference to the Python project, as it would to any volunteer-driven open source effort. And given the insane flows of cash the AI sector is seeing, \$1.5 million doesn't even qualify as a drop in the bucket. It's more like some vapor for the likes of any mainstream commercial AI vendor. At the same time, much as this will be welcome support on the receiving end, we should also acknowledge, right, that it's likely a clever investment on Anthropic's part. The line from the announcement, as I said, that caught my eye, "Planned projects include creating new tools for automated proactive review of all packages uploaded to PyPI..."

Leo: Hallelujah.

Steve: "...improving on the current process."

Leo: Hallelujah.

Steve: So, yes. Automated proactive review. In other words, deploying AI to examine all newly submitted Python Package code. And whose AI do you imagine the Python Software Foundation will choose to deploy? Even if it weren't Anthropic, given Claude's current code analysis strength...

Leo: You'd use Claude anyway. That's right.

Steve: Yes. Anthropic's solution would probably be the one to choose...

Leo: You're not going to use Grok for that.

Steve: They're certainly not going to use a competitor AI with the \$1.5 million. I was kind of wondering if some of that might have been in AI token credit. But they said cash. So anyway...

Leo: Yeah. I think more, every company now uses open source software a lot. In fact...

Steve: And ought to really be supporting.

Leo: Everybody should be doing this. If you're using open source, fund those projects because they're underfunded, and they need help, and you're making money off of them. So put some of it back in.

Steve: I talk a little bit later again about my plans to switch to Let's Encrypt TLS Certs when I'm forced to. And that much as I do for Wikipedia, that sends me a little email every month thanking me for my drip of contribution, I'm going to do the same thing for Let's Encrypt because I'll be using their certificate services for free, and that's a hell of an infrastructure that needs to keep, you know, running and going. So yeah, I agree with you, Leo. I think that's - it's the right model.

One of the more egregious privacy-invading behaviors that has come to light is the idea that car makers might be generating additional revenue for themselves, behind their car owners' backs, by selling data about their individual drivers' driving to insurance companies. The question has been whether or not individual drivers may have consented to this. I would argue strongly that it is not possible to actually "consent" to something that's never explicitly described and explained, and which probably appears in a purchase agreement's legalese fine print.

I've been driving for about 55 years now, and I've purchased a few cars during that time. I've never attempted to read any of the fine print. I presume that as a U.S. consumer my rights will be protected by my government's agencies whose job it is to be a check on

corporate greed, and to make sure that consumers who don't read the fine print get a fair shake nevertheless.

To that end, last Wednesday, the FTC posted an announcement under their headline: "FTC Finalizes Order Settling Allegations that GM and OnStar Collected and Sold Geolocation Data Without Consumers' Informed Consent." They wrote: "The Federal Trade Commission finalized an order with General Motors and OnStar settling allegations that they collected, used, and sold consumers' precise geolocation data and driving behavior data" - you know, like acceleration and braking, we know that the cars are tracking that - "from millions of vehicles without adequately notifying consumers and obtaining their affirmed consent.

"Under the order finalized by the Commission, General Motors LLC, General Motors Holdings LLC, and OnStar, LLC (collectively GM), which are owned by General Motors Company, are prohibited from sharing certain consumer data with consumer reporting agencies. They also are required to take steps to provide greater transparency" - which I would argue is any transparency - "and choice to consumers over the collection, use, and disclosure of their connected vehicle data.

"In a complaint first announced in January 2025" - so this took a year - "the FTC alleged that GM used a misleading enrollment process to get consumers to sign up for its OnStar connected vehicle service and OnStar Smart Driver feature. The FTC also alleged that GM failed to clearly disclose that it collected consumers' precise geolocation and driving behavior data via the Smart Driver feature and sold it to third parties without consumers' consent.

"The final order approved by the Commission imposes a five-year ban on GM disclosing consumers' geolocation and driver behavior data to consumer reporting agencies. This fencing-in relief is appropriate given GM's egregious betrayal of consumers' trust. And for the entire 20-year life of the order, GM will be required to" - and we have four bullet points.

"Obtain affirmative express consent from consumers prior to collecting, using, or sharing connected vehicle data (including sharing data with consumer reporting agencies), with some exceptions such as for providing location data to emergency first responders. Second, create a way for all U.S. consumers to request a copy of their data and seek its deletion. Third, give consumers the ability to disable the collection of precise geolocation data from their vehicles if their vehicle has the necessary technology. And finally, provide a way for consumers to opt out of the collection of geolocation and driver behavior data, with some limited exceptions." Again, like emergency conditions.

"The Commission" - I got a kick out of this. "The Commission," they said, "voted 2-0" - so Leo, both of the commissioners...

Leo: 2-0.

Steve: ...said, okay, we like this.

Leo: Steve and I vote 2-0 that we agree.

Steve: Thank god it wasn't a tie that would have happened. So in addition to General Motors, we know that Hyundai has been found to be sharing its drivers' data with a

company called Verisk. That's one of the major brokers of such information. Both Honda and Toyota are believed to be doing the same.

And, you know, this nauseating spying on the part of automakers feels so similar to the idea of consumer ISPs, like all of the companies that we use to connect us to the Internet, surreptitiously monitoring and tracking their own subscribers' Internet usage and behavior without knowledge or permission technically; right? Maybe it's in, you know, they'll say something down in there about, you know, for business purposes, without ever being express about what it is, just to, you know, their attorneys, like, give them an out legally. And remember, Leo, you used to introduce me on this podcast as the person who coined the term "spyware."

Leo: Right.

Steve: And who created the world's first spyware removal tool. Both of those things are true. I named that first antispymware utility OptOut, and I, oh, I will never forget the raw fury that was expressed in the email end users were sending to that spyware parent's company, at the time named Aureate. They shared some of the email with me. I mean, oh, it was way over the top. I mean, it, like, hire security guards to protect your family. Oh, people were so upset. But that's how people reacted to the affirmative discovery of secretly installed spyware residing inside their machines. It was never my intention to put Aureate out of business. But it turned out that their entire business model was only viable while they remained unknown and secretive. Once people learned about them, no one wanted anything to do with them.

My creation and publication of OptOut generated so much antipathy toward them that I spoke, as I mentioned, to their leadership on several occasions. I came to understand that individually they were not bad people. The Aureate system was a revenue-generation library that shareware and freeware authors could embed into their software to display advertisements on the app's UI surface. So the Aureate system was supposed to "advertising enable" shareware to generate some revenue from the shareware's use.

The BIG mistake Aureate made was in relying upon the freeware and shareware authors to notify their users - it was all about notification. Notify their users that this was taking place. None of their authors did that. Or if they did, again, it was buried down in the software's license agreement that no one ever bothered to read or understand. I explained to the Aureate management that they needed to take independent responsibility for the operation of their system by displaying their own permission dialog to get the end user's permission. Most of the anger - and, oh, was it palpable - was over the fact that this was going on behind people's backs, users' backs. And it just engendered fear; right? I mean, they were afraid of the idea that something was watching them.

So today the names have changed, but the behavior has not. GM knows that if their users were clearly asked whether they would like to have detailed data about their driving habits sold for GM's profit to third parties who would then resell it to their insurance providers to justify increases in their own insurance rates, who would say, "You betcha! Sign me up for some of that!" Nobody; right? Similarly, ISPs know that no one would want to have their detailed use of the Internet resold to data brokers. But ex-ISP employees have said they know firsthand that's happening.

So we know that the opinions and votes of our politicians can deeply influence or can be, their votes can be deeply influenced by commercial interests, you know, through lobbying.

Leo: No.

Steve: So thank goodness we have independent consumer watchdog agencies such as the FTC to watch our backs for us.

Leo: A lot of insurance companies will give you a - this is how they get around this.

Steve: You think it works both ways?

Leo: Yeah. Well, what they do is they offer you as their insured a reduced rate if you agree to be tracked; right. And then they have an app that you can install. So that way...

Steve: But directly with the company.

Leo: Right. It's not - and no car company is making money on that, selling your information without your knowledge. You're agreeing with the insurance company. I think that's okay.

Steve: Yeah. Yeah, yeah, yeah. In that case I would agree.

Leo: That's actually good because that reduces our expense, if, you know, because insurance companies don't want to insure bad drivers; right? They want to insure [crosstalk].

Steve: Right. The other day I showed Lorrie - my 20-plus-year-old beloved BMW sedan died, like, two years ago.

Leo: Ohhh.

Steve: Oh, that's okay. And I replaced it. And since then my aggregated driving shows an average of 26 miles per hour. Now, I...

Leo: You should see what my aggravated driving is. No. That's good, Steve. You follow the speed limit.

Steve: Yeah. So I - not because I want to. It's just that there's cars in my way.

Leo: You live in L.A. area. You can't go any faster, even on the freeway. Hey, I want to correct myself. CPython, I did not know this actually, is the official name of Real Python. It is called CPython because it was written in C.

Steve: Ah.

Leo: C-Y-T-H-O-N, Cython, is the one I was thinking of.

Steve: Ah.

Leo: Which is compiled to C. And that is not a Python Software Foundation project, so they don't get any of the money. CPython is Python. It's the same thing. They just, I don't know, they call it Python.

Steve: Okay. Before we figure out what ANCHOR and CIPAC are, let's take a break.

Leo: Okay.

Steve: And then we're going to figure out what the Department of Homeland Security is up to, and whether the replacement, ANCHOR Council, is going to make anybody happy.

Leo: Yes. All right, Steve.

Steve: Okay. So last year we touched upon the crucial need for industry executives to be able to disclose known security incidents, that is, you know, their own known security incidents, and these are like, you know, infrastructure agencies, you know, major power companies and so forth, to government officials without fear of reprisals from the government. This was the critical role that CIPAC had. I guess CIPAC. CIPAC stood for the Critical Infrastructure Partnership Advisory Council. Last Wednesday, the publication CyberScoop published a very nice piece about the pending replacement agency. CyberScoop wrote: "The Department of Homeland Security is finalizing plans for a new body that would replace the functions of the Critical Infrastructure Partnership Advisory Council (CIPAC) and serve as a communications hub between industry and government to discuss ongoing threats to U.S. critical infrastructure, including from cyber attacks.

"Under previous administrations, CIPAC served as a nerve center for federal agencies, industry, and other stakeholders. While industry widely praised its utility, the council was one of many DHS advisory bodies that were shuttered last year by Secretary of Homeland Security Kristi Noem after President Donald Trump returned to office. Now, according to multiple sources, a proposed regulation for a new replacement council is in the final stages of review and approval from Noem's office.

"The new body will be called the Alliance of National Councils for Homeland Operational Resilience, which has the initials 'ANCHOR,' Alliance of National Councils for Homeland Operation Resilience, and will also serve as an umbrella organization for other federal sector risk management agencies. Its goal is to restart conversations and planning around infrastructure security that took place under the previous CIPAC, according to a former DHS official.

"The official, who requested anonymity to discuss the administration's plans, said all 15 federal sector coordinating councils have been briefed on ANCHOR. One of the primary differences between CIPAC and ANCHOR will be in structural authorities and liability protections." Now, the liability protections is the key issue; right? I mean, that's what

industry executives explained that they desperately needed. The article says: "CIPAC was essentially 'an advisory council that could be chartered to create other advisory councils' that needed Secretary-level approval and contained rigid rules requiring separate charters for every new council that was then stood up."

He said: "This created 'a waterfall effect' of bureaucracy that made CIPAC a poor vehicle for holding broad conversations between not just DHS and industry, but all other federal sector risk management agencies and sector coordinating councils." So it kind of sounds like it may have been, the way it was implemented before, a little bit of a bureaucratic nightmare.

The official said: "What DHS has strived to do is create a new framework for engaging on threat conversations and pre-deliberative policy conversations impacting security outcomes with sectors and the private sector, without having to create all these waterfall advisory councils or new charters and all that stuff." Okay. So, so far that all sounds good; right? Any reduction in needless bureaucracy sounds like a good thing.

CyberScoop's reporting continues, saying: "Under CIPAC" - the original organization - "conversations between government and industry were also 'closed by default,' which is in double quotes, so that was a term of art, 'closed by default' to the public, with mandatory liability protections for every conversation and setting. Often, the most the government could do was issue a press release or cite comments under Chatham House Rule. Under ANCHOR, there is expected to be wider latitude for DHS or other councils to open certain meetings to the public, or provide transcripts of conversations they hold with stakeholders." And of course that could put a chill on the conversations; right? Because previously the government was essentially gagged.

CyberScoop says: "However, the official emphasized that liability protections remain one of the last unresolved issues. The administration is still determining when those protections would or would not apply to ANCHOR-related discussions between government and industry, and further changes could be made to assuage the industry.

"Other federal laws, such as the Cybersecurity and Information Sharing Act of 2015, only provide liability coverage for 'one to one' conversations between a company and the government. The previous entity, CIPAC, by contrast, provided a liability shield for 'one-to-many' engagements, where a company may engage with federal, state, and local agencies, as well as other companies and entities.

"The official said: 'That created a well understood and important liability shield which allowed senior officials, all the way up to the CEO of private sector companies, to openly communicate with each other.'

"Following the initial publication of this reporting, a DHS spokesperson in a statement did not dispute the description of ANCHOR provided by CyberScoop, but called discussions of an imminent regulation release 'premature.' The spokesperson said: 'We look forward to sharing more details once we have something to announce.'

"This week, Adrienne Lotto of the American Public Power Association told Congress that liability protections in CIPAC were critical to fostering open dialogue between industry and government around cybersecurity and infrastructure protection. She also signaled that a new advisory council was forthcoming, saying industry 'was apprised by DHS that the administration's proposed CIPAC replacement is ready for publication in the Federal Register' while encouraging the administration to finalize the plans 'quickly.'

"Even with some uncertainty around ANCHOR's structure and liability protections, many industry executives are likely to embrace the return of information-sharing partnerships that they believe were vital to understanding the digital and physical threat landscape

facing their industry sectors. Last year, industry groups lamented the disbanding of CIPAC to members of Congress, prompting Rep. Andrew Garbarino, now chair of the Homeland Security Committee, to pledge he would 'look into this and hopefully speak to the administration to try to fix this.'

"The former DHS official said they expected ANCHOR to be largely welcomed by many industries who have called for the restoration of CIPAC, even as they look to grapple with the Trump administration's new approach. The official said: 'Everybody who wants to talk in groups is going to be excited to have it back. At the same time, those who are concerned about the amount of risk it opens up will need to see the details.'"

So I clearly recall us reporting on the industry's concern over the disbanding of that original CIPAC, since there are clearly things that the government alone can do, which private industry may need their help with. You know, if nothing else, you know, setting laws and regulations that allow the industry to do what it needs to do. But if a fear of the consequences of divulging serious incidents and problems keeps industries silent, which CIPAC didn't because of its blanket liability protection, then that would not be good for ANCHOR. You know, I like the sound of an improved structure that sidesteps the need to design and spawn endless subcommittees and create charters for them.

And it sounds as though the need for liability protections at least is clearly understood now. So let's hope that, you know, ANCHOR happens, and that it provides the protections that the executives need in order to openly speak with the government at all levels and among themselves.

Okay. So, okay. Leo, the word is German. It's Bundesnachrichtendienst. Bundesnachrichtendienst.

Leo: Perfect.

Steve: And there you have it. So I have some reporting that was obtained from translations from German. And at this point, since it describes Germany's new legislation as "pending" as opposed to "enacted," I didn't want to spend any more time digging into the source material, which would all have needed translation. And also, my assumption is that if or when this does occur, it will have plenty of multi-sourced coverage translated for us in English. So today I'm just going to share the reporting that I have, and everyone will quickly see why it was worth sharing "as is" for now.

So the reporting read: "German lawmakers are working on a new law that will grant the country's intelligence agency new and extensive hacking and surveillance powers. The primary intent of the new law is to free up the..."

Leo: Just say BND.

Steve: Yes, the BND, "from relying on the U.S. National Security Agency (NSA)."

Leo: Oh, yeah.

Steve: Uh-huh.

Leo: Which I think everybody's looking for ways to get around that, yes.

Steve: Yeah, well, because you can't count on it now; right?

Leo: Yup.

Steve: "...for threat information and bring Germany's interception capabilities on par with other European countries, such as France, Italy, the Netherlands, and the UK. According to a draft of the new law obtained by German media, the BND" - everyone knows who they are, I guess it's the equivalent of the NSA, right, the German's NSA is the BND. So, done.

Leo: That's right.

Steve: "...will have the power to intercept full Internet communications, and not just metadata as it is allowed today. The agency will also be allowed to store the data for up to six months, which will allow it to better index and search it for threat intelligence. The BND will also have its offensive hacking mandate extended. The law will allow the agency to hack foreign Internet service providers and retrieve information about its targets if the companies do not cooperate or provide the requested data." What?

"According to reports, this provision will apply to major U.S. companies" - meaning the hackees. This provision, the ability to be hacked by the BND - "will apply to major U.S. companies and infrastructure providers like Google, Twitter, and Meta, which have been known to be prickly" - imagine that - "about surrendering such information in the past. The agency could previously intercept the communications of individuals abroad, but now the BND will also be allowed to put any foreigner in Germany under surveillance. The same goes for journalists working for foreign state-run media organizations, which German lawmakers say are acting more like 'agents' of a foreign state than independent reporters." Wow. "Finally, BND agents will also be allowed to enter apartments and deploy their 'federal trojan' on a target's device."

Leo: Great.

Steve: What could possible go wrong?

Leo: Federal trojan.

Steve: The federal trojan. You've been federally trojanized. "According to reports, the new law's draft is 139 pages long because all the words are as long as the BND is, so you need more pages; right? And that almost doubles the BND's previous capabilities." So I think the short version of what this means is "thank goodness for state-of-the-art encryption."

Leo: Yes.

Steve: Which we have every reason to believe is utterly unbreakable by anyone.

Leo: The math is your friend.

Steve: And while Germany's legislation might at first seem like egregious overreach, we know that the U.S. National Security Agency, our beloved NSA, has already built a massive data center of over one million square feet about 20 miles South of Salt Lake City, Utah. And while the details are kept close, it's well known to be a massive data storage facility. We've often noted that there may be value in storing massive quantities of encrypted data, and probably selectively, that cannot be deciphered today, but may be decipherable using tomorrow's technology.

So it's easy to imagine that the internal encrypted communications of the U.S.'s global adversaries may be tapped and tagged and sent to Utah for long-term archiving. And then, once the NSA's quantum computing technologies come online in the future, the public key crypto handshakes that established the ephemeral secret symmetric keys might be broken, and those communications, even though by then no longer current, still might be important to obtain.

So I sometimes feel that the EFF's, the Electronic Freedom Foundation's, absolutism about privacy rights and encryption goes a little overboard. You know, like, boy, do their knees jerk quickly. But when we see examples like this, of how aggressively foreign governments and our own are pursuing information that for the most part they probably have no need for, they're just sucking it up because they can, I appreciate that the EFF is working to always provide some counter-pressure against these tendencies because, you know, there does just seem to be an increase in this going on, Leo.

Leo: Yeah. Perfect forward secrecy protects us against this ultimately, though; right?

Steve: No, it doesn't.

Leo: No?

Steve: No. Because all that's happening there is that the perfect forward secrecy means that the key is changing.

Leo: Right.

Steve: So but the key is changing because you're continually renegotiating during the communication. But all of those renegotiations are similarly interceptable.

Leo: Oh, okay, So they have that, too.

Steve: Yeah. So if it were a very static key, then that would be worse because you just break one key...

Leo: You just get it all at once, yeah.

Steve: And you get the entire conversation. Here, you do need to be doing successive rekeying and, you know. But the NSA presumably is able to do that.

Leo: So the new key is arranged using the old key.

Steve: Yeah.

Leo: So once you get the old key, you can then find the new key, and then you continue to do that as a chain. All right.

Steve: Yeah.

Leo: That's why they're saving everything. They can have my old messages.

Steve: Yes. You know, and again, we know law enforcement bitches and moans more than they ever have, but they have also never had a greater wealth of data. All of us went online rather than, you know, walking around and doing things. And all of this data is being tapped. So it's not that like there's any great dearth of information available.

Leo: No.

Steve: Okay. So we appreciate that it could happen to anyone. You shared your story with us last week, Leo.

Leo: Sigh. My humiliation, yes.

Steve: I shared that I almost, you know, I got a little text that initially, like, oh, that looks - and then I went, whoops. Anyway, it now appears that someone inside Grubhub clicked a link they should not have, which permitted the infamous ShinyHunters gang to obtain authentication credentials. BleepingComputer, which reported on this exclusively last Thursday, headlined their reporting: "Grubhub confirms hackers stole data in recent security breach."

BleepingComputer wrote: "Food delivery platform Grubhub has confirmed a recent data breach after hackers accessed its systems, with sources telling BleepingComputer the company is now facing extortion demands." Grubhub told BleepingComputer: "We're aware of unauthorized individuals who recently downloaded data from certain Grubhub systems. We quickly investigated, stopped the activity, and are taking steps to further increase our security posture. Sensitive information, such as financial information or order history, was not affected."

Now, they wrote: "Grubhub would not respond to any further questions regarding the breach, including when it occurred, whether customer data was involved, or if they were being extorted. However, the company confirmed that it is working with a third-party

cybersecurity firm and has notified law enforcement." In other words, clearly something happened.

"Last month," BleepingComputer wrote, "Grubhub was also linked to a wave of scam emails sent from its b.grubhub.com subdomain that promoted a cryptocurrency scam promising a tenfold return on Bitcoin payments. Grubhub said at the time that it contained the issue and took steps to prevent further unauthorized messages, but would not answer further questions related to the incident. It's unclear whether the two incidents are connected.

"While Grubhub would not share further details, multiple sources have told BleepingComputer that the ShinyHunters cybercrime group is extorting the company. BleepingComputer attempted to verify these claims with the threat actors," meaning the ShinyHunter guys, "but they, too, refused to comment."

Now, I'll interject here that the threat actors' silence at this juncture would be expected, since part of their promise in return for receiving an extortion payment would be their silence. Since they presumably still hope that the returns from their data breach will result in a payday, much as they have shown a willingness to brag in the past, they're certainly not going to talk to the press until it's clear that doing so would not compromise their negotiations and their extortion payout, if any.

BleepingComputer continues: "According to sources, the threat actors are demanding a Bitcoin payment to prevent the release of older Salesforce data from a February 2025 breach and the newer Zendesk data that was stolen in the recent breach." And of course that all tracks the reporting that we've been doing here, where we noted that a month or two ago the ShinyHunters gang had switched to attacking Zendesk users after they had apparently fully played out their multiple earlier Salesforce breaches.

BleepingComputer concludes, writing: "Grubhub uses Zendesk to power its online support chat system, which provides support for orders, account issues, and billing. While it's unclear when the breach occurred, BleepingComputer was told that it was through secrets and credentials stolen in the recent Salesloft Drift data theft attacks." So the attacks that keep on giving.

"In August," they wrote, "threat actors used stolen OAuth tokens for Salesloft's Salesforce integration to conduct a data theft campaign between August 8th and August 18th of 2025. According to a report by Google's Threat Intelligence team (Mandiant), the stolen data was then used to harvest credentials and secrets to conduct follow-up attacks on other platforms. Google reported by their TIG, their Threat Intelligence Group, that UNC6395" - that's their formal nomenclature for ShinyHunters - "targeting sensitive credentials such as Amazon Web Services and access keys, passwords, and Snowflake-related access tokens." ShinyHunters claimed at the time to be behind the breach, stating they stole approximately 1.5 billion data records from the Account, Contact, Case, Opportunity, and User Salesforce object tables for 760 companies. So that was a major, somewhat downplayed event and attack.

And Leo, we're at an hour. Let's take a break, and then we're going to talk about the availability of Let's Encrypt's six-day certs, now available, fortunately only if you want them.

Leo: Six days, wow.

Steve: Yeah.

Leo: I might vibe code an ACME cert downloader so that I don't have to think about this anymore. What could possibly go wrong?

Steve: Last Thursday, January 15th, Let's Encrypt announced under their headline "6-day and IP Address Certificates are Generally Available." They wrote: "Short-lived and IP address certificates are now generally available from Let's Encrypt. These certificates are valid - get this, Leo - for 160 hours."

Leo: Wow.

Steve: Just over six days.

Leo: That's forever.

Steve: Yeah. "In order to get a short-lived certificate, subscribers simply need to select the 'short-lived' certificate profile in their ACME client. Short-lived certificates improve security by requiring more frequent validation and reducing reliance on unreliable revocation mechanisms. If a certificate's private key is exposed or compromised, revocation has historically been a way to mitigate damage prior to the certificate's expiration. Unfortunately, revocation is an unreliable system, so many relying parties continue to be vulnerable until the certificate expires, a period as long as 90 days." Well, yeah, 90 for them. With short-lived certificates that vulnerability window is greatly reduced.

"Short-lived certificates are opt-in, and we have no plan to make them the default at this time. Subscribers that have fully automated their renewal process should be able to switch to short-lived certificates easily if they wish, but we understand that not everyone is in that position and generally comfortable with this significantly shorter lifetime. We hope that, over time, everyone moves to automated solutions, and we can demonstrate that short-lived certificates work well. Our default certificate lifetimes will be going from 90 days down to 45 days over the next few years, as previously announced.

"IP address certificates allow server operators to authenticate TLS connections to IP addresses rather than domain names. Let's Encrypt supports both IPv4 and IPv6. IP address certificates must be short-lived certificates, a decision we made because IP addresses are more transient than domain names, so validating more frequently is important. You can learn more about our IP address certificates and the use cases for them from our post announcing our first IP Certificate. We'd like to thank the Open Technology Fund and Sovereign Tech Agency, along with our Sponsors and Donors, for supporting the development of this work."

And as I said before, the shortening of the maximum lifetime of web server DV domain validation certificates will eventually drive GRC, my company, to use Let's Encrypt's free certificates. Once I switch to their solutions, I will definitely establish a periodic voluntary payment to them, much as I have with Wikipedia, as I mentioned at the top of the show, since I feel that it's important to support the infrastructure that makes that possible, even if the entire necessity of any of this is something I could not disagree with more. So be it.

It's never been clear to me who has such a problem holding onto their web server's private keys. All indications are that the entire thing is a made-up problem. Remember that even if a bad guy could somehow arrange to obtain a valuable domain's certificate,

it's not as if just having that in any way allows them to impersonate the target site. They must still somehow arrange to cause their victim's Internet traffic to believe that it's going to the real domain's IP address, while it is instead re-routed to a spoofed server where the stolen certificate resides. So you need either a DNS compromise also, or some physical interception and re-routing of the actual packet traffic must be achieved, none of which is easy to do, either.

So if this was ever happening - if it ever happened - it would be big news. We would know about it. Instead, crickets. And I get it that the Let's Encrypt guys need to say that revocation is broken. I understand that. But that is no longer true.

I have a picture of going to revoked.grc.com on the screen. Anyone's invited to go to revoked.grc.com. It says: "Error code: SEC_ERROR_REVOKED_CERTIFICATE." No browsers are fooled any longer. And any of our long-term listeners know that I was onto all of this, pointing this out and drawing attention to this as loudly as I could, before anybody else was doing so. I looked a little foolish at the time, like I was tilting at windmills, saying that this was a problem. You know, what's the big deal? I created that "revoked.grc.com" site to clearly demonstrate that none of this was working at the time. It is now, everywhere. And it's even been solved quickly on the client side, with no privacy compromise, thanks to Bloom filters, which we talked about in detail with this specific application.

And just so that I'm clear, I think it is truly great that Let's Encrypt is now offering six-day TLS DV and IP validated certificates - for those who feel they need them. I don't know why anyone would, but okay. Great. It's the being forced to use shorter life certificates, whether for the web or for code signing, that feels so wrong and regressive to me. I don't need a nanny. Few of us do. And as I've said, if anyone did, like if this was actually a problem, it would be making news. The only news it's making is that it's, you know, discomfiting everybody who's having to use these increasingly short-lived certificates for no apparent reason.

Okay. Several news outlets are reporting, have reported on something that caught my attention, mostly because it's so sad and, in my opinion, wrong-minded. The news is that the country of Iran plans to extend its current disconnection from the Internet, which began in the evening of January 8th, their time, permanently. Which is hard to even believe, but yes. Technical reports have indicated that efforts are being made to restrict the use of messaging apps for internal use only. All satellite dish antennas of all ilk are being gathered up, and technology is being finalized to identify network traffic that transits across Starlink and other space-based providers.

Iran's ruling theocracy, you know, it is what it is. It's been clear that the influence of the West, largely through, you know, although I guess I would say largely though not exclusively brought to Iran by the Internet, it's been a challenge to the nature of its historical theocratic rule. But Iran's population today is not old. Its median age is somewhere between 33 and 34. Meaning that half of Iran's population is younger than 33 to 34, somewhere in that range, and currently about a quarter of the population are children under the age of 15. So cutting that population off from all external Internet access certainly seems destined to fail in the long run. Okay. I just wanted to report on that. I imagine we'll be looking at that in the future, if in fact that continues.

I have, as I mentioned at the top of the show, I've received from one of our listeners and a SpinRite user a pair of charts that I had never seen before, and I got a big kick out of them. I wanted to share them. The listener's name is Donn, with two n's, Donn Edwards. He wrote: "Dear Steve: You have often mentioned how SpinRite improves SSD performance, and we've seen the results of its benchmark tests. But here is a different view. My friend panicked when his computer would not boot. It has a Crucial 480GB SSD boot disk, and a Seagate 1TB hard drive data disk. Not knowing whether the problem

was hardware related or not, I rescued the drives" - he meant removed the drives - "and connected the SSD to my own desktop PC to see if the data was intact. All appeared fine, so I ran HD Tune to look at the SMART data and run its benchmark."

And he included the chart for the before SpinRite alongside the chart for the after. He said: "The drop in performance (shown in the HD Tune Pro chart on the left), particularly at the start of the drive" - actually it's about the first two thirds - "was troubling, so I ran SpinRite 6.1 on Level 3, and it took around three hours. I could see it having trouble writing to the drive, but in the end no data was lost."

"Afterward," and he says see the post-SpinRite chart on the right, "it's clearly fixed. I backed up all the data files from his hard drive and put both drives back in the PC. When we plugged in all the cables and screens, his PC worked. So whether it was the SSD, or a bad cable connection, or something else, I don't know. But what I do know for sure is that his SSD is working much better than before. The graphs show it, and he is very relieved. Keep up the good work. Donn Edwards, Johannesburg, South Africa."

And Leo, you can see there on the left the - many people are familiar with HD Tune. This is showing the drive's speed across its mass storage surface, essentially. So from 0GB to 480GB, and the top of the chart is 450MB/second. You would expect a solid-state drive being solid state, right, would just be a straight line. People who have run HD Tune on spinning drives see a characteristic downward stepping in performance, typically going to about half speed by the time they get to the inner cylinders of the drive because those cylinders having a shorter circumference, the data transfer rate is much lower because they have many fewer sectors. Here, instead, on this well-used SSD, we see like deep downward spikes coming almost down to 50MB/second from the normal of around, well, looks like about 425.

And it's really bad for past the halfway point, and then it goes up high. And in fact what's interesting then is if you look at the chart on the right, you'll see first of all it's all gone from - it's got completely fixed from running a SpinRite Level 3 on the drive. You do see a little bit reduction in an area that used to be, that used to look full speed. The reason is, and this surprised us when we began working with SpinRite, those areas on the chart on the left were not actually being read. That's not actually 425GB/second. Those areas had been trimmed. So the drive knew they had never been written to. And so it was just giving back zeroes. It was sending zeroes back. After running SpinRite across the drive, those areas were written to by SpinRite.

As soon as the operating system retrim the drive, which happens - you're able to do it on demand, by command, if you wish. Just running the little optimize command in Windows does a retrim on the drive. Then it'll run right back up to flat line at maximum speed. But what really matters here is that a drive that was running, like, one-eighth as fast as it should, and it wasn't booting because there were some errors which didn't show up in Donn's just quick mounting of the drive where it looked like he saw all the files, SpinRite fixed those problems and also restored the drive to its original performance. Anyway, just a very cool set of charts, using a third-party utility that many of our listeners are used to.

Okay. Jeff Ekstrand wrote: "You can find" - oh, this is so cool. "You can find the advertising ID on Roku via some secret menus. On the remote you can do some convoluted button pushes to access these menus. One of them contains the advertising ID. I do not remember which one." Then he provided a cheat sheet. So, and it happens that, I mean, I played with it. It's the secret screen number two is where the advertising ID is found. This all relates to us talking about the California legislation where you're able to give CalPrivacy this information, and then they provide it to the data brokers using that information to help find you in order to force them to scrub your data, and to no longer offer it for sale.

So if you have a Roku, you press the Home button five times, then up, right, down, left, up. So you sort of go around the arrow pad clockwise, Home button five times, then up, right, down, left, up. And sure enough, that suddenly switches the screen, and there was my advertising ID, which was a grid formatted identifier, you know, four sets of hyphens with hex code, hexadecimal code of various sizes. So there's a developer settings screen, a wireless secrets screen, a secret screen, secret screen #2 - that's where the advertising ID was - an HDMI secret screen, a platform secret screen, channel info menu, and a reboot shortcut. Although I'm not sure how much of a shortcut that is. You have to hit the Home button five times, then Up, then the Rewind button twice, and the Fast Forward button twice. It's pretty much easier just to use the normal menus. Anyway, I've got a link to the YouTube video that this guy found for us. And, you know, there's a bunch of other information. As is generally the case, and I'm sure you've see this too, Leo, these sorts of hidden Easter Eggs, they initially look like, oh, you found some massive treasure trove. But it's kind of internal counters and stuff that don't really have much value.

Leo: It's just cool that you can get there.

Steve: Like what's your MAC address? It's like, okay. I mean, and yeah, the MAC address is there for Bluetooth and WiFi and so forth. So if you want that, you can find it. Anyway, thank you very much, Jeff. I appreciate that. And it's an 11-minute YouTube. It was posted two months ago, on November 19th. It has had 1.2 million views. So this seems to be of interest to some people. Anyway, I got a kick out of it. Thank you, Jeff.

Michael Wright said: "Hello, Steve. I'm a first-time emailer to you who has been listening to your show for a couple of years now and find it a great resource to keep up with developments in the world of cybersecurity. Thanks so much for the podcasts.

"I'm a week behind with the podcasts and today finished last week's podcast. You made a good point about how there should be no legitimate reason for anyone to have their MongoDB server accessible over the Internet. That got me wondering if people are deploying MongoDB servers without even realizing they are publicly accessible. I'm referring to cloud deployments, where for many flavors of deployment, a public IP address is automatically created. With traditional on-prem, making a server accessible over the Internet required work to be done." Right. You've got to poke a hole through, typically through a NAT or a firewall or something. I mean, you have to work in order to create a public presence. I think he's right there.

He said: "For example" - oh, yeah. He's making my point - "creating a NAT rule on a firewall to translate a public IP address to a private IP address. However, with public cloud, this is often done automatically. If people are deploying systems to the cloud without having an understanding of cloud deployment and how this differs from on-prem, I could certainly see how it could be possible to deploy a system without realizing you just made it accessible to anyone anywhere on the Internet. It would be interesting to know how many of the 86,000 exposed servers are using IP addresses reserved for public cloud. Keep up the great work. P.S.: On the topic of British time travel series," he said, "I found 'Bodies' to be a pretty good effort. Certainly a different take on the subject. Not sure if you've seen that. Regards, Michael."

So I suspect Michael is right, and that many of those MongoDB server instances are spun up in the cloud. And although this may be an explanation, it certainly isn't an excuse. What's happening is very wrong. So the question is, how did this happen? It's likely a case of the user assuming that "those in charge" are doing the right thing; whereas "those in charge" wrongly assume that their users are aware of the implications of

spinning up random server instances in the cloud, and they assume that those users will prevent public exposure if they don't want it.

In other words, one hand doesn't know what the other one is doing, and they each assume that the other one is taking responsibility for the expected (and needed) network security. The problem is that those who design these system services, you know, heavily promote their super ease of use, you know, one-click server activation. So they're offering their inherently insecure solutions to a level of user who has very little comprehension, if any, of the full implications of clicking on that "Yes, please create a MongoDB server instance for me" button.

I wanted to focus on this specific instance because I suspect that this lack of communication with its assumption that the other party is taking care of securing things has long been a major source of network insecurity for the entire industry. Several months ago I noted that the early Cisco routers, which had no built-in notion of public-facing WAN interfaces versus private-facing network LAN interfaces, they treated all of their network interfaces identically. There was no concept of LAN and WAN. Those early routers also had their various network services enabled out of the box.

Back then, for example, you had to manually add a "nohttp" command to the router's start-up configuration script if you did not want the router's built-in http server to be running by default. I very clearly recall needing to deliberately turn off a handful of services that I knew I had no need for and I certainly didn't want to have running every time that the router booted. And I had to do that every time I set up a Cisco router. The engineer/designers of these early routers must have assumed that their devices would only and always be used by other expert network engineers.

And since Cisco was always selling the "security" of their products as one of its benefits, non-expert purchasers reasonably assumed that Cisco would have their back, and that the router's operation would be secure out of the box, when it was anything but. Instead, as we know, it was bristling with enabled and insecure gee-whiz features that were entirely peripheral to the router's core operation. So the lesson here is that each side's assumptions about the other were wildly incorrect, and serious vulnerabilities resulted. This is why a couple months ago when I read that piece from the guy at Cisco, who, like, you know, made it clear that if this actually came to pass, they really did finally understand what was going on. So thank goodness.

Still, we just need more communication. And as we've said, these devices absolutely have to be secure out of the box, and you have to take serious deliberate action to damage their security, to do things which are insecure, and maybe you have to be asked are you sure, and maybe you need to be asked are you really sure.

Okay. So I got an email from someone named Bob, whose note was "Cyber Attack - Was My Experience Unique?" He wrote: "Hello, GRC Team. I've been a big fan and SpinRite customer since learning about your SpinRite product on The Tech Guy." Remember that, Leo?

Leo: Oh, I've heard of that show, yeah.

Steve: Uh-huh. He said: "Recently, I experienced a type of cyber attack I had not heard of. I can go into more detail, but basically, a program, ScreenConnect, was remotely installed on my PC and launched with no interaction by the client (me)." He said: "I became aware of the attack when I was at my mom's house, and my phone started notifying me of money transfers that I did not initiate. I freaked out, as you might imagine. I rushed home, and when I got there, I found that my machine had been

hijacked. My screens were blacked out with 'ScreenConnect' in large white letters. I was unable to do anything other than shutting down the machine."

Leo: Yikes.

Steve: "Needless to say, I've been dealing with the aftermath, and fortunately I'm not out too much money. But I found out who my friends and foes are in terms of how they did or did not help me cancel the transactions. In short, PayPal's response was abominable. I assume the criminal used a sniffer to find my IP address. And since my machine was idle, they were able to install and launch ScreenConnect without detection," he said, parens, "(no client interaction to install and launch the software is considered a feature of the product)." He said: "In my opinion, the software is like a gun. Misuse can lead to devastating results. They offer a free 15-day trial, but I didn't check to see if it is full featured.

"What do you think about this? Short of keeping my machine powered off, what could I have done to block this type of attack? Any insight would be appreciated. Regards, Bob."

Okay. So this is the nightmare scenario for any individual. I've omitted Bob's last name to protect his identity. No one wants to be required to authenticate with every service we use, every time we use them. Right? So being persistently logged into many services is the choice most of us make. But with that convenience, that persistent logged-on convenience comes the consequence that anyone - and anything - that's able to use our persistently logged in computer can act on our behalf.

The abuse of persistent logon is what bit Bob. Bob doesn't know, so we don't know, exactly how someone managed to crawl into his PC. Through the years of this podcast we've seen many different ways this could have happened. But by far the most likely is that Bob or someone using Bob's computer clicked on a malicious link. Last week, as we mentioned, Leo, you shared your own incident which forced you to cancel and have two credit cards reissued. And I mentioned that I had received a text message that I briefly considered to be valid because by pure chance it fit into the context of my life, and it made sense to me.

So it's certainly not the least bit far-fetched to imagine that Bob, or someone who uses Bob's PC, might have made the mistake of clicking on a malicious link in email. Or maybe on a web page, who knows. That's all that's needed. That could have established an outgoing connection to an attacker who was then able to install the "client-free" ScreenConnect remote control software. The attacker could then have waited until that PC had been left running and unattended, and it could determine that through no use of its keyboard or mouse for some period of time. Then they took the opportunity to begin sending the owner's money to remote accounts.

For example, PayPal allows zero-authentication transfers of cash from the bank accounts and credit cards associated with a person's PayPal account if they remain logged into PayPal statically. It just brings up a dialog onscreen. You click, you know, complete the transfer, and the money is gone.

So when Leo and I speak to the attendees of ThreatLocker's Zero Trust World conference in Florida this coming Wednesday, March 4th, our discussion will be titled "The Call is Coming from Inside the House." We're going to be talking about the growing need for enterprises to actively protect themselves from anything their own employees might do. Whether it's deliberate or inadvertent doesn't matter since the result to the enterprise is the same either way.

Doing this effectively means imposing significant limitations upon everyone who has access to the enterprise's internal network. I'll be arguing that while it will not be at all easy, there is no longer any other way to further increase security from where we are today. Given everything we've seen in the past year, it's clear that the spoofing of enterprise employees is the next "big growth" threat vector.

But for the individual PC user at home, no one wants to impose severe restrictions upon themselves when they're working within their own safe enclave in their residence. I certainly wouldn't. In this case, this happened to Bob because his PC was able to act without his physical presence to send his money out. The practical solution to this would be the inclusion of a simple biometric authentication for anything that requires Bob's presence. Having a fingerprint reader integrated into our keyboards or mice to confirm the identity of anyone who is requesting a protected action would prevent these sorts of unattended or other-attended attacks.

And, for example, a sponsor of this podcast, Bitwarden's Password Manager fully supports unlocking with biometric authentication on Windows, macOS, and Linux, and also using with all Chromium-based browsers, Firefox, and Safari. So setting this up would certainly be possible. Of course it means incurring this overhead all the time because there's no way to know if and when someone might get a hold of your computer behind your back. And even so, this still leaves user-spoofing as a problem since something happened to compromise Bob's PC to start with. The most reasonable explanation of how ScreenConnect remote control software found its way onto Bob's machine is that something he did deliberately, maybe downloaded and installed some piece of software that incorporated this malicious functionality as a backdoor without ever realizing it.

So even biometric authentication would not have prevented that initial event because it was done by him. But requiring authentication for every single high-risk transaction might. We're not there yet. But I wouldn't be surprised if in the future that's the shape of things. There are available keyboards and mice both that have fingerprint readers built in. And Windows Hello can be engaged to require them for specific actions. So it kind of feels like where we're going to go. It's unfortunate, but if someone wants to really protect their machine against their own or somebody else's who shares their machine's misuse, something like that's going to be necessary.

And Leo, we're an hour and a half in. Let's take a break, and we're going to continue with feedback.

Leo: Indeed, indeed. Yeah, I think Bob doesn't really know how he got hacked. It's very...

Steve: Well, yeah, and behind a NAT, I'm sure he's behind a NAT router. Everybody is. And so you just can't, you know, just getting his IP doesn't allow somebody in.

Leo: Yeah, I just wanted to say that so that people don't go, well, wait a minute, my computer's always on. We used to have people who'd say, no, you have to turn your computer off when you're not at it. Which as a security precaution, no. I don't, I mean, I guess it would work.

Steve: I turn none of mine off. When I talked about the solution I've come up with after Lorrie and I move in a couple months, that I've got the dumbest laptop with the biggest screen I could find, because I'm going to connect to my computer, you know...

Leo: It's a terminal.

Steve: It's a terminal. And my machine is never turned off.

Leo: Right.

Steve: It's like, you know, it's just 24/7.

Leo: I know people who not only turn off their machines, but disconnect the Ethernet cable just in case.

Steve: And it's like GRC's servers. I've got servers. They're publicly exposed. They're servers. They have to be publicly exposed. You don't turn them off.

Leo: Right. But, you know, I used to get calls all the time on The Tech Guy show. I'm not surprised Bob listens to The Tech Guy show because that was - I'd always get people say, they hacked me just by, you know, I didn't do anything. The problem is, when you click on that link, you don't know that that malicious link did anything. Life goes on.

Steve: Right.

Leo: And then it's later they exploit you.

Steve: And if you download some software that is going to be like to sort your spreadsheets or something, you know, oh, look, it sorted my spreadsheets. Yes. And it also ran ScreenConnect persistently in the background waiting for you to go visit your mom.

Leo: Yeah. Yeah.

Steve: Rob Sherman. His subject was "Feedback on Claude AI." He said: "Hi, Steve. I just finished listening to last week's SN episode, and as someone who's been using it constantly since the update came out I wanted to give you some feedback. In short: It is absolutely insane how good it is. I'm a Product Manager and not a programmer. So when my CTO told me that I needed to try it, I wasn't sure why. I am now."

He said: "I had an internal project that I have been waiting to get programmer resources for over six months. Once I got Visual Studio setup with Copilot, I gave it my product brief. And after answering a few simple questions that Claude had, it began coding. An hour later I had a fully functioning Alpha. It did all the coding, designed and built a UI, and implemented a scanner to get all the data out. Since then, when I have a few hours, I'll just go in and tweak it. That dark mode I've been asking for last year, it's in there. The toggle for it is labeled 'I finally got my dark mode.'"

Leo: That's the beauty of having hyper personalized software, that can be the name of the switch. I love it. I love it.

Steve: The build reporting and error checking I was told we wouldn't be able to do? It's done.

Leo: Oh, wow.

Steve: I have also completed three other projects that we weren't supposed to get to until Q3. It's amazing. I am so sold on it that I got myself a personal license and this weekend did a write-up on the E-drum application I've been waiting for someone to build. I gave it to Claude, and now I have my very own Alpha version.

Leo: So addictive. I completely know how this guy feels.

Steve: He says: "This is not to say that it has been 100% smooth sailing. There's a learning curve to Claude especially, and I have blown through 200% of my monthly request at work in 14 days." He said: "A few tips for anyone looking to get started with this.

"First, your individual 'chats' with Claude have a size limit. Once you hit that limit, you have to start a new chat. If you're just asking it a simple question, you will be fine; but any larger projects you will run out of room. I recommend starting any project by having Claude write up a programming plan and tracking document. Then have it keep those files updated. That way, if you have to start a new chat, you can tell it to go read those docs to get up to speed. That's sort of like chaining these chats together," he says.

Leo: Yeah.

Steve: "Second, Claude (in Visual Studio Copilot) won't let you upload PDF or other docs, but you CAN add MD files. I have taken to having ChatGPT summarize any files and turn them into MD format, which I can then put into my project repo. Once in there, Claude is all set.

"Third, Claude WILL lie to you. It is always a good idea to have it double-check its own work. I had it write a bunch of new code. When it was done, I told it, 'Hey would you take a look at this new code and check it for errors?' It found four items that needed fixing. Thanks for everything you do. Rob." And he said: "P.S.: Started taking magnesium last week." So Leo, on the subject of Claude?

Leo: It is very addictive. He is just starting to get into it. So there's a few things I would say about his tips.

Steve: Okay.

Leo: One is, yeah, he's talking about token context. And when you get the - the context starts to fill up, it starts to hallucinate. That's when it starts to hallucinate.

Steve: Oh, okay. Interesting.

Leo: There are a lot of tools out there for compacting tokens, for handling this. He needs - what you probably should do is start going to YouTube and looking at some best practices. Anthropic has a bunch of videos. But there are other people who have put together a bunch of videos on best practices with Claude. And then you want to start looking at Claude skills and plugins because there are a lot of plugins.

For instance, the double-check its own work, there are some really good plugins that Claude will use to find flaws, to double-check itself. There's plugins for security assays. I have Claude do regular security assays, not just on the stuff it writes, but on everything in my system because it's very good at finding flaws. As you start to use it, you will see more and more of stuff that you can do and get it really refined. It's revolutionary. I even - I don't think I've ever seen anything this - reminds me of first discovering the Internet. It's amazing. And I'm glad...

Steve: And the things you're explaining sound like the early days, like, you know, in three years...

Leo: Oh, it's the Wild West.

Steve: ...this will all be automatic. It'll be built in. I mean, it feels like, you know, we're in the learning curve stage, the fact that these things have to kind of be learned and figured out and added and done afterwards and so forth.

Leo: Well, even, it's funny, even Anthropic, the creators of Claude, they don't know all of the ins and outs. There was a guy, I told you about Ralph Wiggum, the Ralph Wiggum tool; right? That was created by just somebody else who said, you know, if you told Claude to keep going, to keep looping over and over again until it got to a state that you submitted, like no more errors, it will. And in fact Anthropic said, oh, that was a really good idea. And they've now added Ralph Wiggum as part of their official plugin.

So there's more. What we're seeing, there's one called Superpower. Harper Reed, who - that's the other thing. If you can find a guru, somebody who's been using Claude and really knows how to use it, that helps, too. Harper Reed is my personal guru on this. He was on TWiT on Sunday. And he uses something called Superpower, which adds a bunch of very good plugins. I would check. He says, "You use Superpower, of course, Leo." I said, uh, no, what's that? And I went and found it. Most of the stuff's on GitHub. There are a lot of YouTube videos. Yeah, you're just getting started. It's amazing. And it's easy to blow through your credits. That's why I ended up getting the Claude Mac subscription. Which, by the way, has been sufficient, so that's good.

Steve: We want them to stay in business. And if people are getting, you know, I mean, it sounds like it would be easy to get \$200 a month worth of value out of it if you were really using it.

Leo: I feel - that was the question. I thought, is this worth it? And then I thought, you know, if I were going to buy software to do these things, I'd spend a lot more than that.

Steve: And it would never be - it wouldn't be customized. It wouldn't be exactly what you wanted.

Leo: Right. Yeah, look what Rob's done. He's just getting started, and look at all the things he's done already.

Steve: Yeah.

Leo: Your trust in Claude will improve as you understand it better and understand where the pitfalls are and things like that. It actually can be pretty, I think, very, very reliable.

Steve: And again, we have pitfalls because this is the, you know, baby steps.

Leo: It's the Wild West. We're figuring it out.

Steve: We're just learning to crawl, yes.

Leo: Yeah. And that was my other thought is I don't want to add too many of these third-party features and other things because I feel like they're - Anthropic is basically building this in over time. So Claude's getting better and better and better, so you don't need to do as much extending it. I hope as time goes by it'll probably be able to do everything you want it to do automatically. Yeah, compact your context.

Steve: And where do you - we were talking before we began recording because I was talking about a conversation that I listened to you having on MacBreak Weekly about how, you know, from my standpoint, having been programming for about 55 years now, what I recognize is that, for me, the maturity that I have acquired over these decades is about how to solve the problems, not the syntax of the language. I could use any language.

Leo: Exactly.

Steve: It's the structure, like, it's the refinement of the understanding of how this kind of problem should be solved.

Leo: I agree.

Steve: How does that fit into Claude? I mean, it is using other output in order to produce. So is it getting that? Or I guess I wonder from that kind - from that approach to maturity of coding, or is it just kind of like solving the problem brute force?

Leo: Like you, I want to believe that we are adding something of value, and our many years of experience matter. But I have to say there are people like Rob who've never programmed, who are writing pure English prompts.

Steve: And it's working.

Leo: And we're getting the job done. And it's working. I think, I mean, like you, I am not as good as you or as experienced as you, but I think like a programmer, I think. So I tend to approach Claude in a more modular way. I don't write single prompts and say just write it and get back to me when you're done. It's still an iterative process for me. And I feel like I get better results by iterating with Claude. So in that case, your history of - really what humans are great at is pattern recognition; right? In your history - which is what happens in chess, too.

Steve: I think that's intuition.

Leo: We think of it as kind of flash of intuition. But really it's pattern recognition. And you get good at playing chess by playing hundreds of thousands of games and seeing hundreds and thousands of positions and internalizing that. And then it's not even a conscious process. You go, oh, yeah, well, that, I know what you, that's.... And it's the same thing with coding, I think. It's pattern recognition. In fact, they talk about design patterns in coding. And so I think it's a higher level. You're not writing login code. But you understand that, well, I'm going to need some login code here. I'm going to want to encrypt my secrets here so I don't accidentally commit them to GitHub.

And so all of that experience is, I think, still valuable. Obviously Rob, who doesn't have that experience, still can get what he wants done. I love that he named it "I finally got my dark mode." It's hysterical. But that's what - that's the level you're working at now is you're writing your own stuff for yourself. I think it's just super empowering.

Steve: Well, and - yeah. It does sound also like it's not instant because he, like, started it going and went off and had dinner and then, you know, came back, and it had done it.

Leo: This is one of the big breakthroughs that's just happened in the last few months is this ability for this to run continuously for many hours. That's brand new. And I'm a little uncomfortable with it, to be honest. That's why I like to do it more modular.

Steve: Because it, like, it just like completely hallucinates Skynet?

Leo: Makes me nervous.

Steve: I mean...

Leo: But that's why you use things like Ralph Wiggum. You use some of these plugins to control it. So lots of people are running multiple Claudes at the same time, threads at the same time. This seems to be more and more the best practice for these big things. And then have the...

Steve: How much does he provide in financing to Anthropic?

Leo: It can get expensive. You get expensive. But what happens is you can actually have I want you, you this thread, you Claude #1, check on Claude #2. Make sure he's not doing anything weird. So you can - they call it a mixture of experts now. And you can even do that, or have other - you could have ChatGPT look at the Claude code. I mean, its inception, it's a very interesting world. And you're right, this is why it's fun to get into because it's Wild West now. Even the expert, Andrej Karpathy, the man who created the term "vibe coding," tweeted on Christmas Day, he says: "I can't keep up. It's too fast. I can't follow it anymore. There's too much going on." It is an explosion right now of interesting ideas. And I think we are very, very close to some big AI breakthroughs.

Steve: I think it feels like it's going to change the world.

Leo: It's happening.

Steve: I mean, you know, here for the last 20 years we've been lamenting, you know, security errors in code. In five years they may be gone.

Leo: I can't imagine that Claude code would write a buffer overflow. It's just not going to - it's not going to use strcpy.

Steve: Yeah.

Leo: It's just not going to. It knows better than that. Now, there will be subtler things. One of the things people point out with AI is, if it can't - this is a coding hallucination. I got a divide by zero error. Instead of making sure you don't divide by zero, you just hide the error. That's the equivalent of a Claude code hallucination.

Steve: Ah.

Leo: Hide the error. The error doesn't go away. So you've got to watch for things like that. That's the level it's hallucinating at. But I think it's - I think you can say pretty surely that this will all be ironed out.

Steve: Yup.

Leo: I think there's no reason...

Steve: This all feels like first steps sorts of things, just intuitively.

Leo: Yeah. Yeah.

Steve: Wow.

Leo: And you can teach Claude code not to make any of those fundamental security errors. Just don't, you know, that's bad, don't do that.

Steve: Bad Claude.

Leo: No more strcpy.

Steve: Okay. Last sponsor, and then we're going to talk about the, unfortunately, the return or the persistence or the previous existence, the previous unknown existence of GhostPosting.

Leo: I've got to find out what that is. That's a good name for it. That's, by the way, at least 50% of the battle if you're doing malware detection is having a good name.

Steve: Oh, got to have that. Yeah, yeah. I mean, the reason we all know Heartbleed is it was such a great name, a great logo.

Leo: Exactly.

Steve: Dripping blood.

Leo: Exactly. All right. We're going to get back to Security Now! and GhostPosting. Whooooo. Whooooo, as Paris Martineau would say. Let's get to Ghost Peppers. No, not Ghost Peppers.

Steve: Okay, so GhostPosting.

Leo: GhostPosting.

Steve: Okay. So our final podcast of 2025 was titled "GhostPoster." For the short summary at the top of the show notes, I summed it up by writing "How a PNG Icon was used to infect 50,000 Firefox users."

Leo: Oh, man.

Steve: The discoverer of 17 different malicious Firefox add-ons was Koi Security, K-O-I. They discovered that PNG icon files were being used to contain and infiltrate obscured JavaScript into user PCs through Firefox extensions. Some of the extensions were FreeVPNs, and others were junk extensions that someone who just wanted to collect free browser add-ons might add to their browsers. Nevertheless, more than 50,000 Firefox users had this malicious code running inside their browsers. So one of our takeaways was to avoid collecting crap from obscure sources that you don't really need. And, by the way, the phrase "FreeVPN" is an oxymoron.

Leo: Yes. Do not. No.

Steve: There's something wrong. There's something wrong with a free VPN, folks, because, you know, it goes along with free lunch. Okay. So that was Episode 1057. Why are we back here four weeks later for Episode 1061? It's because following Koi Security's discovery, a different firm, LayerX, has reported their discovery of an additional 17 of the same, but this time they're not just attacking Firefox. Users of Edge and Chrome turn out to have been even earlier targets. And get this, with more than 840,000 downloads and installations. So 840,000 downloads and installations. Unfortunately, these attacks are incredibly effective, lucrative, and that's - we know what that means; right? They're going to continue.

LayerX's disclosure headline was "Browser Extensions Gone Rogue: The Full Scope of the GhostPoster Campaign." So here's what we now learn from LayerX's follow-on research. They wrote: "Last month, researchers from Koi Security published a detailed analysis of a malicious Firefox extension" - actually extension family - "they dubbed GhostPoster, a browser-based malware leveraging an uncommon and stealthy payload delivery method: steganography within a PNG icon file. This innovative approach allowed the malware to evade traditional extension security reviews and static analysis tools." Right? Because nobody expected an icon to contain any malicious code. But nor did they expect it to be intelligible. It's a compressed image. So it's just going to be noise. Not so much.

They said: "Following their publication" - meaning Koi's publication - "our investigation identified 17 additional extensions associated with the same infrastructure and tactics, techniques, and procedures (so-called TTPs). Collectively, these extensions were downloaded over 840,000 times, with some remaining active in the wild for up to five years. The GhostPoster malware employs a multi-stage infection chain designed for stealth and persistence.

"Payload Encoding: The initial loader is embedded within the binary data of an extension's PNG icon. Runtime Extraction: Upon installation, the extension parses the icon to extract the hidden data, a behavior that deviates from typical extension logic. Delayed Activation: The malware delays execution by 48 hours or more, and only initiates command-and-control server communication under specific conditions. And finally, Payload Retrieval: The extracted loader contacts a remote command-and-control server to download additional JavaScript-based payloads.

"After activation, the malware is capable of stripping and injecting HTTP headers to weaken web security policies, for example, HSTS and CSP. Hijacking affiliate traffic for monetization. Injecting iframes and scripts for click fraud and user tracking. Programmatic CAPTCHA solving and injection of additional malicious scripts for extended control. These features indicate that the campaign is not only financially motivated, but also technically mature, emphasizing operational stealth and longevity. Right. I mean,

these things were there in the extension stores for Edge, Firefox, and Chrome, for five years in some cases.

"The infrastructure," they wrote, "uncovered by Koi Security was linked to 17 Firefox extensions, all sharing similar obfuscation patterns, command and control behavior, and delayed execution strategies. Our automated Extension malware lab feature confirmed the same threat actor infrastructure and was also able to distribute extensions on the Google Chrome and Microsoft Edge add-ons Store. Our analysis shows the campaign originated on the Microsoft Edge browser, with later expansion into Chrome and Firefox."

So I have in the show notes a timeline, for anyone who's interested. It provides a chart which shows that the first known extension infected Edge browser users back in February of 2020. And none of this was known until just last month. So from 2020 it's been there. About six weeks later, at the end of March of 2020, Firefox was first hit. It was hit again at the beginning of May. Then a run of eight more malicious Edge extensions were released over the course of two years, from the end of August 2020 through the end of September 2022. A month later, at the start of October 2022, the first Chrome extension was created. Then things were quiet for nearly two years until another - because, you know, these extensions existed, and they were just sitting there doing their business. Two years later, another Edge extension appeared in August of 2024. But then after that it was all Firefox from the end of October 2024 to today.

So it's interesting that throughout all this time, only two known malicious extensions were seen to affect Chrome. It would be interesting to know why, since that's clearly, Chrome is clearly the largest potential source of user installations. But in any event, 840,000 is a lot of malware out there. The LayerX people expanded upon Koi's earlier findings, and they reported: "17 additional confirmed extensions, with infrastructure overlap and common loader patterns," meaning certainly from the same people. "More than an additional 840,000" - so that's on top of the 50 that Koi found - "bringing us to 890, almost 900,000 cumulative installs across Firefox, Chrome, and Edge. Malicious presence dating back to 2020, indicating long-term operational success, bypassing all major browsers stores' security checks."

So these bad guys, now six years ago, found a way to slip malware past all the stores' security checks by encoding them in the back end of a PNG icon. And, they said "malware variants using alternate delivery mechanisms," which suggests that there's still ongoing experimentation and adaptation.

Now, beyond the previously identified extensions, we observed a more sophisticated and evasive variant associated with the campaign, which by itself accounted for 3,822 installs. I have a picture of it in the show notes, only because anybody would install this. It shows Firefox browser add-ons. It's got a nice-looking icon. It's called Instagram Downloader. And it's by Instagram Download, available on Firefox for Android. It's got 28 reviews at a 4.4, seems reasonable. And currently 3,822 users. And there's a nice button, download Firefox and get the extension. Who wouldn't do this? I mean, this is the problem. This looks like a legitimate useful thing.

So in this iteration, which the LayerX people found, the malicious logic is embedded within the background script and leverages an image file bundled inside the extension as a covert payload container. At runtime, the background script fetches the image and scans its raw byte sequence for the delimiter in decimal, it's 62,62,62,62, which corresponds to the ASCII string of a sequence of four less-than symbols. All data following that marker is decoded as text and stored persistently in `chrome.storage.local` under the key "instlogo." The stored data is later retrieved, Base64-decoded, and dynamically executed as an additional JavaScript payload.

This secondary script introduces further evasion by deliberately sleeping for approximately five days before initiating any network activity. This of course is to thwart security analysis, you know, security researchers will load up a browser with stuff, set it to running, and watch to see what it does. They generally won't wait for five days. Users do. Five days afterwards, upon activation, it fetches content from a remote server, extracts server-supplied data stored as Base64-encoded keys, and executes the decoded content, enabling ongoing payload updates and extended control. This staged execution flow demonstrates clear evolution toward longer dormancy, modularity, and resilience against both static and behavioral detection mechanisms.

They said: "While Mozilla and Microsoft have removed the known malicious extensions from their respective stores, extensions already installed on systems remain active unless explicitly removed by the user. This persistence underscores the limitations of store takedowns as a containment strategy, particularly for malware employing delayed activation and modular payload delivery."

Okay, now, they listed a bunch of their 17. Something called Page Screenshot Clipper only had 86 downloads. The Full Page Screenshot had 2,000 downloads. The Convert Everything, whatever that is, had 17,171. But the Translate Selected Text with Google had just shy of 160,000 downloads. And among the biggest was by all time the number one was Translate Selected Text with Right Click had 522,000 downloads. So this translation hook seems to be offering something that people want. Unfortunately, these things were malicious.

Leo: They're not going to say something you don't want.

Steve: No.

Leo: They're going to say something you want; right?

Steve: Right. And what this is teaching them is that by offering these bogus translation apps, they're able to get a lot of downloads. So that's clearly a hook that interests people.

Leo: They figured out what it is people are going to download for free.

Steve: Yeah.

Leo: It can't be too valuable, or you wouldn't think it was free.

Steve: Right.

Leo: So it's got to be something, like, kind of simple and cool.

Steve: Well, like that Instagram Downloader; right? You know, while we all might determine that something seems fishy about an offer of a free VPN, that screenshot that

we showed of the Instagram Downloader looks entirely legitimate. And I can imagine downloading it without ever being the wiser.

Leo: [Crosstalk] ready because it's easy for bad guys to write this stuff now. I mean, the vibe coding that makes it easy for us to write what we want...

Steve: Yup. Yup.

Leo: ...makes it easy for them, too.

Steve: That's really true. One thing that puzzles me is LayerX's suggestion that the removal of extensions from the web store leaves any already downloaded and installed extensions in place and dangerous. We know that all the browser vendors have the ability to remotely disable any browser extensions that are found to be malicious. I suppose it might be the case that a malicious extension that its malicious publisher withdraws from the store might slip under the radar since it's no longer being offered. If it's removed from the store, maybe it just doesn't raise a beacon. And it might also be that the post-installation mechanisms which these extensions use, by moving their later downloaded code into the browser's permanent store, affords them some post-removal protection. I don't know.

Leo: Ah, yeah.

Steve: But the convincing appearance of that Instagram Download extension is, as I said, that seems unnerving to me. It's important to note that Koi was aware of around 50,000 downloads and installs because, for whatever reason, they apparently were not looking back far enough.

The instrumentation that the LayerX people had gave them five years of history, and they found 840, or they found 17 more extensions whose downloads totaled more than 840,000. So I think one of the important takeaways here is that we must always remember that we can never know what we don't know. There's no point in getting overly worked up over things that we cannot control, nor excessively worrying over what we don't know. I would just say don't, you know, like, be skeptical. Don't install extensions just because, you know, you've got room on your toolbar for more of them.

Leo: Yeah. Seems like a good, useful tool.

Steve: You know, keep to the things - keep to the things you need and that, like, seem that they come from real known legitimate enterprises. I mean, I've obviously, I've got BitLocker? What am I trying to say? BitLocker? No, not BitLocker.

Leo: Bitwarden?

Steve: Bitwarden, thank you. I was just drawing a blank. I'm sitting here looking at it. I've got Bitwarden sitting on my toolbar, and a few other things that I trust that I've

been using for years, you know, the vertical tabs extension for Firefox and a few other things. But I just avoid more. And that would be the advice for everybody.

Leo: But this is the rule of thumb for all software.

Steve: Yes, yes.

Leo: Install as little software as possible; right?

Steve: It's not just browser extensions. It's, you know, it's like the Browser Download Helper. Who needs help downloading a file?

Leo: We used to. We used to. That was a very common category.

Steve: I know.

Leo: It's still in some people's heads, probably the Boomers amongst us. But yeah, this was always - I started saying this on a regular basis on The Tech Guy show. Really the real rule is install as little as possible. You know, if you just got your iPhone and left it with just the stuff it came with, you'd be far better off, with performance, with battery life, and for safety.

Steve: Yup. As I mentioned, I'm very much a living-off-the-land guy. You know, I don't want to install something else if I've already got functionality there.

Leo: That's why I install Emacs everywhere, and that's it. That's all you ever need, really. Plus, as easy as it would be to write a malicious plugin for Emacs, I don't think anybody's going to do that. The pickings are slim, let's put it that way. Steve, what a great show. Always, always look forward to Tuesdays. And I hope you do, too, everybody. Make sure you're here.

Copyright (c) 2014 by Steve Gibson and Leo Laporte. SOME RIGHTS RESERVED

This work is licensed for the good of the Internet Community under the Creative Commons License v2.5. See the following Web page for details:
<http://creativecommons.org/licenses/by-nc-sa/2.5/>